

MITRE ATT&CK Lab

November 7th 2025

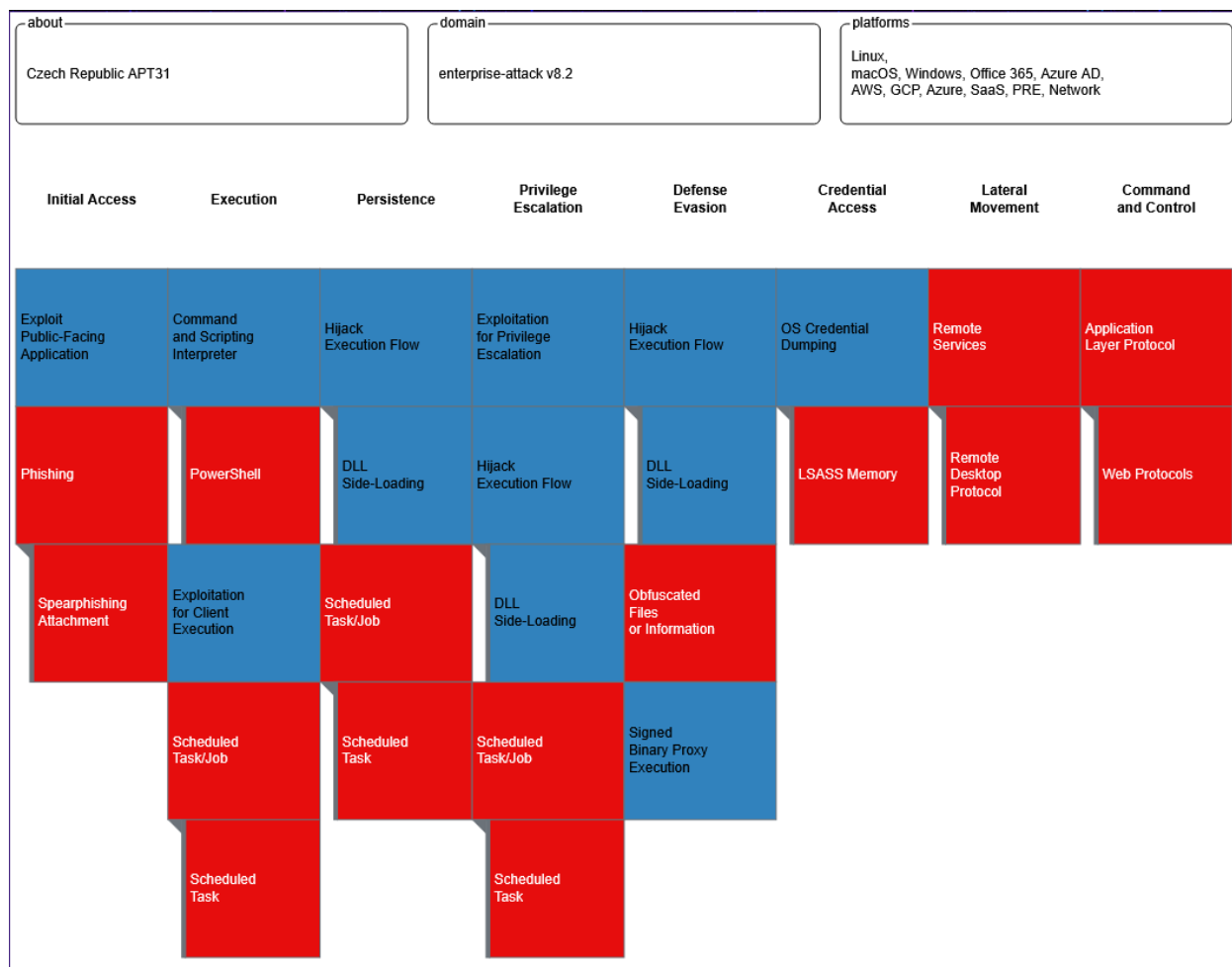
Rena Sani

November 2025

Introduction

The advanced persistent threat group APT31 has been publicly attributed with the cyber espionage campaign targeting the Czech Republic foreign affairs ministry. The attack exploited vulnerabilities in Microsoft SharePoint (CVE-2025-49706 and CVE-2025-49704) to deploy the ToolShell post exploitation framework, allowing APT31 persistent access for several years. The Czech intelligence agencies confirmed this attribution with high confidence citing APT31 style behaviors. This activity has prompted the Czech Republic to summon China's ambassador and formal condemnation of the cyber activity.

MTIRE ATT&CK Mapping (SVG Image)



Blue: Techniques Directly Correlated to the Czech Republic case

Red: Common techniques seen from APT31 – likely used in the Czech case but might be too early to tell if each were specifically used

MITRE ATT&CK Mapping (Excel Export)

Tactic	Technique	Threat Actor Activity	Detection Recommendations
Initial Access	Spearphishing Attachment (T1566.001)	The attacker used phishing emails with malicious attachments (such documents or PDFs) to trick users into opening files that executed malware.	Implement email security filters to detect and quarantine emails with suspicious attachments or links. Train users to identify and report phishing emails.
Initial Access	Exploit Public-Facing Application (T1190)	APT31 targeted public facing SharePoint server (CVE-2025-49706 and CVE-2025-49704)	Monitor for unusual POST requests to SharePoint endpoints.
Execution	Command and Scripting Interpreter (T1059)	APT31 used the ToolShell post-exploitation framework for remote command execution and lateral movement	Look for encoded PowerShell commands and flag the use of Invoke-Expression, DownloadString or remote URLs
Execution	Scheduled Task (T1053.005)	APT31 often uses scheduled tasks to maintain persistence and trigger ToolShell/PowerShell payloads.	Monitor task creations (Windows Event ID 4698) and detect usage of schtasks.exe/create. Especially flag tasks executing for temp directories or user profiles.
Execution	Exploitation for Client Execution (T1203)	APT31 targeted public facing SharePoint server (CVE-2025-49706 and CVE-2025-49704)	Monitor for unusual POST requests to SharePoint endpoints.
Persistence	DLL Side-Loading (T1574.002)	APT31 sideloaded malicious DLLs using legitimate applications to execute payloads	Detect legitimate apps loading DLLs from non-standard paths such as C:\ProgramData\ or Temp

Wk10 MITRE ATT&CK Lab

Persistence	Scheduled Task (T1053.005)	APT31 often uses scheduled tasks to maintain persistence and trigger ToolShell/PowerShell payloads.	Monitor task creations (Windows Event ID 4698) and detect usage of schtasks.exe/create. Especially flag tasks executing for temp directories or user profiles.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	The threat actor exploited software or system vulnerabilities to gain higher-level privileges and access restricted areas of the network.	Make sure all operating systems and applications are regularly patched and updated. Monitor for abnormal privilege escalation and new administrator account creation.
Privilege Escalation	DLL Side-Loading (T1574.002)	APT31 sideloaded malicious DLLs using legitimate applications to execute payloads	Detect legitimate apps loading DLLs from non-standard paths such as C:\ProgramData\ or Temp
Privilege Escalation	Scheduled Task (T1053.005)	APT31 often uses scheduled tasks to maintain persistence and trigger ToolShell/PowerShell payloads.	Monitor task creations (Windows Event ID 4698) and detect usage of schtasks.exe/create. Especially flag tasks executing for temp directories or user profiles.
Defense Evasion	DLL Side-Loading (T1574.002)	APT31 sideloaded malicious DLLs using legitimate applications to execute payloads	Detect legitimate apps loading DLLs from non-standard paths such as C:\ProgramData\ or Temp
Defense Evasion	System Binary Proxy Execution (1218)	APT31 abused legitimate windows binaries to avoid detection	Flag the use of rundll32.exe, mshta.exe and wmic.exe with suspicious arguments.
Defense Evasion	Obfuscate Files or Information (T1027)	APT31 often obfuscates payloads to deliver via phishing or web exploits, such as ToolShell modules or PowerShell scripts.	Detect the use of - EncodedCommand or base64 strings in PowerShell. Also search for suspicious file extensions such as double extensions (.txt.exe)
Credential Access	OS Credential Dumping (T1003)	The threat actor used credential dumping tools to extract stored usernames and passwords from system memory and registry for lateral movement.	Monitor for suspicious processes accessing LSASS.exe or reading credential stores. Enable Credential Guard and restrict access to sensitive system files.

Lateral Movement	Remote Desktop Protocol (T1021.001)	APT31 historically has used Remote Desktop Protocol (RDP) to move laterally across a network after gaining valid credentials	Monitor windows event id 4624 with LogonType=10 (Remote Interactive) and scrutinize logins including unusual Ips, Accounts, or Times (Impossible travel)
Command and Control	Application Layer Protocol (T1071.001)	APT31 established C2 communication using encrypted HTTPS to bypass network monitoring	Monitor outbound HTTPS traffic to rare domains that are long-lived with low data volumes

Incident Debrief

A long-term espionage campaign was launched against the unclassified network of the Czech Ministry of Foreign Affairs. The behavior was traced back to APT31, a threat actor affiliated to China's Ministry of State Security. Attackers most likely gained access through phishing and using legitimate accounts. Once inside, they stayed hidden, moved through the network, and stole sensitive diplomatic information. The attack showed careful planning and strong security skills typical of state-sponsored hackers.

Recommendations

Defenders should look for odd or high-risk logins right away in identity and email logs (Azure AD sign-in logs and Microsoft 365 Unified Audit Logs). Turn on MFA for all remote and privileged accounts, audit mailbox permissions and delegation, and rotate any potentially compromised credentials. Turn on scheduled-task logging (Events 4698–4702), process-creation auditing (Event ID 4688), and PowerShell Script Block Logging. Keep an eye out for WMI-based persistence, new or altered scheduled tasks, and encoded PowerShell instructions. Examine outgoing network traffic for unusual connections to file-sharing or public cloud services that could point to data exfiltration. To prevent such conduct, use DLP controls and

egress filtering. Use the Sparrow tool to confirm domain-trust settings and the Hawk and CrowdStrike Report Tool to find additional devices or assigned mailbox access. Maintain a precise inventory of IP ranges that face the internet and perform authorized vulnerability assessments on all internal and external assets on a regular basis. Finally, follow Zero Trust principles, segment sensitive networks, save logs for at least 90 days, and do frequent threat hunting for APT31-related TTPs.

References

- Deutsche Welle. (2025, May 28). *Czech Republic summons Chinese ambassador over cyber attacks – DW – 05/28/2025*. dw.com. <https://www.dw.com/en/czech-republic-summons-chinese-ambassador-over-cyber-attacks/a-72699971>
- Dvořáková, A. (2025, May 28). *The Czech government has publicly attributed cyberattacks to China: Actor apt31 linked to the Chinese Ministry of State Security has targeted the infrastructure of the Czech Ministry of Foreign Affairs*. National Cyber and Information Security Agency. <https://nukib.gov.cz/en/infoservis-en/news/2263-the-czech-government-has-publicly-attributed-cyberattacks-to-china-actor-apt31-linked-to-the-chinese-ministry-of-state-security-has-targeted-the-infrastructure-of-the-czech-ministry-of-foreign-affairs/>
- The Hacker News. (2025, May 29). *Czech Republic blames China-linked APT31 hackers for 2022 Cyberattack*. <https://thehackernews.com/2025/05/czech-republic-blames-china-linked.html>
- Martin, A. (2025, May 28). *Chinese spies blamed for attempted hack on Czech Government Network*. Cyber Security News | The Record. <https://therecord.media/czechia-accuses-china-cyber-espionage-apt31>
- Mitre ATT&CK®. MITRE ATT&CK®. (n.d.). <https://attack.mitre.org/>
- Statement by the Government of the Czech Republic*. Ministerstvo zahraničních věcí České republiky. (n.d.). https://mzv.gov.cz/jnp/en/issues_and_press/press_releases/statement_by_the_government_of_the_czech.html

Detecting post-compromise threat activity in Microsoft Cloud Environments | CISA. CISA - America's Cyber Defense Agency. (2021, April 15). <https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-008a>